Πολιτική Ασφάλειας Πληροφοριών

CULTURE
FOR
CHANGE

ΕΙΣΑΓΩΓΗ

Η Πολιτική αφορά το Σωματείο με την επωνυμία «Culture for Change» και με τον διακριτικό τίτλο «CforC», το οποίο εδρεύει στην Αθήνα επί της οδού Λ. Αλεξάνδρας 48, ΤΚ 11473, ΑΦΜ 996788256, ΔΟΥ Δ' Αθηνών. (επικοινωνία: hello@cultureforchange.net)και εκπροσωπείται νομίμως.

Αυτό το έγγραφο ορίζει τις πληροφορίες της πολιτικής ασφάλειας του οργανισμού

Ως σύγχρονος και προοδευτικός οργανισμός αναγνωρίζει την ανάγκη να διασφαλίσει ότι λειτουργεί ομαλά και χωρίς διακοπή προς όφελος των μελών, συνεργατών και άλλων ενδιαφερόμενων μερών.

Προκειμένου να παρέχεται ένα τέτοιο επίπεδο συνεχούς λειτουργίας, έχει εφαρμοστεί ένα σύνολο ελέγχων ασφάλειας πληροφοριών για την αντιμετώπιση ενδεχόμενων κινδύνων των πληροφοριών και των προσωπικών δεδομένων.

Η ασφάλεια της πληροφορικής έχει πολλά οφέλη, όπως:

- Προστασία των ροών εσόδων και της σωστής οικονομικής διαχείρισης.
- Διατήρηση και ενίσχυση της αξίας της ως παρουσία στον χώρο.
- Συμμόρφωση με τις νομικές απαιτήσεις προστασίας των προσωπικών δεδομένων

Αυτή η πολιτική ισχύει για όλα τα συστήματα, τους ανθρώπους και τις διαδικασίες που αποτελούν τα πληροφοριακά συστήματα του οργανισμού συμπεριλαμβανομένων μελών του διοικητικού συμβουλίου, συνεργατών, προμηθευτών και άλλων τρίτων που έχουν πρόσβαση στα στοιχεία του.

Τα παρακάτω έγγραφα αφορούν την παρούσα πολιτική ασφάλειας πληροφοριών και παρέχουν πρόσθετες πληροφορίες σχετικά με τον τρόπο εφαρμογής της:

- Πολιτική Φορητών Συσκευών
- Πολιτική Κωδικών Πρόσβασης

- Πολιτική Ασφάλειας Φυσικής Πρόσβασης
- Πολιτική Anti-malware
- Πολιτική Ηλεκτρονικών Μηνυμάτων
- Πολιτική Προστασίας Δεδομένων
- Πολιτική Αποδεκτής Χρήσης

ΠΟΛΙΤΙΚΗ ΑΣΦΑΛΕΙΑΣ ΠΛΗΡΟΦΟΡΙΩΝ

ΑΠΑΙΤΗΣΕΙΣ ΑΣΦΑΛΕΙΑΣ ΠΛΗΡΟΦΟΡΙΩΝ

Οι απαιτήσεις για την ασφάλεια των πληροφοριών στον Οργανισμό θα προσδιοριστούν ξεκάθαρα και θα συμφωνηθεί, τόσο εσωτερικά στην οργανωτική του δομή, όσο και με τους εξωτερικούς συνεργάτες, ότι όλη η δραστηριότητα ασφάλειας πληροφοριών θα επικεντρωθεί στην εκπλήρωση αυτών των απαιτήσεων καθώς και στην ασφάλεια των προσωπικών δεδομένων που υφίστανται επεξεργασίας μέσω των πληροφοριακών συστημάτων και των τηλεπικοινωνιακών μέσων του. Στο σχεδιασμό εντάσσονται και απαιτήσεις νομικές, κανονιστικές και συμβατικές.

Είναι θεμελιώδης αρχή του προγράμματος ασφάλειας πληροφοριών ότι οι εφαρμοζόμενοι έλεγχοι πηγάζουν από τις ανάγκες του οργανισμού και αυτό θα κοινοποιείται τακτικά σε όλα τα μέλη και τους συνεργάτες, μέσω συνεδριάσεων και εγγράφων ενημέρωσης.

ΠΛΑΙΣΙΟ ΓΙΑ ΤΟΝ ΚΑΘΟΡΙΣΜΟ ΤΩΝ ΣΤΟΧΩΝ

Ο καθορισμός των στόχων στην ασφάλεια των πληροφοριών, θα γίνεται σε τακτά χρονικά διαστήματα, και θα λαμβάνεται υπόψη στον ετήσιο σχεδιασμό. Με τον τρόπο αυτό θα εξασφαλιστεί η επαρκής χρηματοδότηση για τις δραστηριότητες που εντοπίστηκαν και απαιτούνται με σκοπό τη βελτίωση του συστήματος ασφάλειας.

Οι στόχοι αυτοί θα βασίζονται στη σαφή κατανόηση των επί μέρους δράσεων, και θα ενημερώνονται διαρκώς μέσα από διαδικασίες επανεξέτασης κατά τις οποίες θα καταγράφεται η άποψη των εμπλεκόμενων μερών.

Οι στόχοι ασφάλειας των πληροφοριών θα τεκμηριώνονται για μια συμφωνημένη χρονική περίοδο, μαζί με τις λεπτομέρειες για τον τρόπο με τον οποίο θα επιτευχθούν. Όλα αυτά, θα αξιολογηθούν και θα

παρακολουθούνται από τη διοίκηση για να διασφαλιστεί ότι παραμένουν έγκυρα. Εάν απαιτούνται τροποποιήσεις, αυτές θα γίνονται μέσω της διαδικασίας διαχείρισης αλλαγών.

Οι έλεγχοι ασφάλειας πληροφοριών θα υιοθετούνται, κατά περίπτωση και θα επανεξετάζονται σε τακτική βάση, ανάλογα με τα αποτελέσματα από τις αξιολογήσεις κινδύνου και σε συνδυασμό με τα σχέδια αντιμετώπισης κινδύνου.

ΣΥΝΕΧΗΣ ΒΕΛΤΙΩΣΗ ΤΗΣ ΑΣΦΑΛΕΙΑΣ ΠΛΗΡΟΦΟΡΙΩΝ

Η πολιτική του Οργανισμού όσον αφορά τη συνεχή βελτίωση είναι

- Να βελτιώνει συνεχώς την αποτελεσματικότητα των ελέγχων ασφάλειας πληροφοριών και προσωπικών δεδομένων
- Να βελτιώνει τις τρέχουσες διαδικασίες ώστε να ευθυγραμμίζονται με τις νέες ανάγκες
- Να αυξάνει το επίπεδο πρόληψης (και την αντίληψη των ενδιαφερομένων για την προληπτική δράση) όσον αφορά την ασφάλεια των πληροφοριών και των προσωπικών δεδομένων
- Να καταστήσει μετρήσιμες τις διαδικασίες και τους ελέγχους ασφάλειας πληροφοριών, ώστε να παρέχουν μια στέρεη βάση για τεκμηριωμένες αποφάσεις
- Να αναθεωρεί τις σχετικές μετρήσεις σε ετήσια βάση ώστε να ελέγχεται εάν είναι σκόπιμο να γίνουν αλλαγές βάσει των συλλεγόμενων ιστορικών δεδομένων
- Να αποκτά νέες ιδέες για τρόπους βελτίωσης μέσω τακτικών συναντήσεων και άλλων μορφών επικοινωνίας με τα ενδιαφερόμενα μέρη
- Οι νέες αυτές ιδέες να αναθεωρούνται σε τακτικές συνεδριάσεις διαχείρισης, προκειμένου να δίνεται προτεραιότητα και να αξιολογούνται τα χρονοδιαγράμματα και τα οφέλη

Ιδέες για βελτιώσεις μπορούν να ληφθούν από οποιαδήποτε πηγή, συμπεριλαμβανομένων μελών, συνεργατών πληροφορικής, εκτίμησης κινδύνων και αναφορών εξυπηρέτησης (service reports). Μόλις εντοπιστούν, θα καταγράφονται και θα αξιολογούνται ως μέρος των ανασκοπήσεων.

ΠΕΡΙΟΧΕΣ ΠΟΛΙΤΙΚΗΣ ΑΣΦΑΛΕΙΑΣ ΤΩΝ ΠΛΗΡΟΦΟΡΙΩΝ

Ο οργανισμός ορίζει πολιτικές στους τομείς που σχετίζονται με την ασφάλεια των πληροφοριών, οι οποίες περιγράφονται λεπτομερώς σε αντίστοιχο ολοκληρωμένο έγγραφο τεκμηρίωσης πολιτικής, που συνοδεύει αυτήν την γενική πολιτική ασφάλειας πληροφοριών.

Κάθε μία από αυτές τις πολιτικές ορίζεται και συμφωνείται από ένα ή περισσότερα άτομα με αρμοδιότητα στον σχετικό τομέα και, μόλις εγκριθεί επισήμως, κοινοποιείται σε κατάλληλο κοινό, τόσο εντός όσο και εκτός του οργανισμού.

Ο παρακάτω πίνακας παρουσιάζει τις μεμονωμένες πολιτικές στο σύνολο τεκμηρίωσης και συνοψίζει το περιεχόμενο κάθε πολιτικής και το κοινό-στόχο των ενδιαφερόμενων μερών.

Τίτλος Πολιτικής	Πεδίο Εφαρμογής	Στοχευμένο Κοινό
Πολιτική Φορητών Συσκευών	Φροντίδα και ασφάλεια κινητών συσκευών όπως φορητοί υπολογιστές, tablet και smartphones, είτε παρέχονται από τον οργανισμό είτε από το άτομο για επαγγελματική χρήση.	Οι χρήστες των κινητών συσκευών, είτε αυτές παρέχονται είτε χρησιμοποιούν δικές τους συσκευές.
Πολιτική Κωδικών Πρόσβασης	Καταχώριση και διαγραφή χρηστών, παροχή δικαιωμάτων πρόσβασης, εξωτερική πρόσβαση, αναθεωρήσεις πρόσβασης, πολιτική κωδικού πρόσβασης, ευθύνες χρήστη και έλεγχος πρόσβασης συστήματος και εφαρμογών.	Συνεργάτες/Μέλη που εμπλέκονται στη δημιουργία και διαχείριση ελέγχου πρόσβασης
Πολιτική Ασφάλειας Φυσικής Πρόσβασης	Ασφαλείς περιοχές, ασφάλεια εγγράφων και εξοπλισμού και διαχείριση κύκλου ζωής εξοπλισμού	Όλοι οι Συνεργάτες/Μέλη
Πολιτική Anti-Malware	Firewalls, anti-virus, φιλτράρισμα ανεπιθύμητων μηνυμάτων, εγκατάσταση και σάρωση λογισμικού, διαχείριση ευπάθειας, κατάρτιση ευαισθητοποίησης χρηστών, παρακολούθηση απειλών και ειδοποιήσεις, τεχνικές αναθεωρήσεις και διαχείριση περιστατικών κακόβουλου λογισμικού.	Συνεργάτες/Μέλη που είναι υπεύθυνοι για την προστασία της υποδομής του οργανισμού από κακόβουλο λογισμικό
Πολιτική Ηλεκτρονικών Μηνυμάτων	Αποστολή και λήψη ηλεκτρονικών μηνυμάτων, παρακολούθηση ηλεκτρονικών διευκολύνσεων ανταλλαγής μηνυμάτων και χρήση ηλεκτρονικού ταχυδρομείου.	Χρήστες συστημάτων ανταλλαγής ηλεκτρονικών μηνυμάτων
Πολιτική Προστασίας Προσωπικών Δεδομένων	Εφαρμοστέα νομοθεσία για την προστασία των δεδομένων, ορισμοί και απαιτήσεις.	Οι Συνεργάτες/Μέλη που είναι υπεύθυνοι για το σχεδιασμό και τη διαχείριση συστημάτων που χρησιμοποιούν προσωπικά δεδομένα